



sec4her: introduzione CTF (Capture The Flag)

1. Che cos'è una CTF?

CTF è l'acronimo di Capture The Flag, che in italiano significa letteralmente "cattura la bandiera". Nel campo della sicurezza informatica, una CTF è una competizione o un ambiente di apprendimento in cui i partecipanti devono risolvere problemi tecnici, analizzare sistemi e individuare informazioni nascoste, spesso con l'obiettivo finale di trovare una stringa chiamata flag.

Le CTF sono utilizzate per imparare e mettere in pratica le conoscenze di cybersecurity attraverso esercizi concreti. A differenza dello studio esclusivamente teorico, permettono di sperimentare direttamente come funzionano programmi, reti, applicazioni e sistemi informatici.

Per esempio, una sfida potrebbe chiederti di decifrare un messaggio, analizzare un file sospetto, individuare una vulnerabilità in un sito web di laboratorio oppure comprendere il funzionamento di un programma.

Ogni sfida presenta un obiettivo specifico e mette alla prova determinate capacità tecniche e logiche.

Le CTF possono essere affrontate individualmente oppure in squadra. Alcune sono progettate per principianti, mentre altre richiedono conoscenze avanzate di programmazione, reti, sistemi operativi e sicurezza informatica.

È importante capire che una CTF non consiste necessariamente nell'attaccare un computer. Molte sfide richiedono soltanto di analizzare dati, risolvere enigmi, interpretare codice o comprendere il funzionamento di un algoritmo.

2. Che cos'è una flag?

La flag è una stringa di testo che rappresenta il risultato richiesto da una determinata sfida. Quando il partecipante riesce a risolvere il problema, può ottenere questa stringa e inserirla nell'apposito campo della piattaforma CTF.

Una flag può avere un formato simile al seguente:

```
flag{hai_risolto_la_sfid}
```

Oppure:

```
CTF{messaggio_segreto_123}
```

Questi sono esempi illustrativi: il formato effettivo dipende dalla competizione.

La flag può essere contenuta in un file, nascosta in un'immagine, ricavata da un programma oppure ottenuta analizzando una vulnerabilità presente in un ambiente di laboratorio.

Per esempio, potresti ricevere un file di testo contenente una sequenza di caratteri che non sembra avere significato. Analizzandola, potresti scoprire che si tratta di una codifica Base64. Decodificando correttamente la sequenza, potresti ottenere la flag.

La flag serve quindi a dimostrare che hai raggiunto l'obiettivo della sfida.

3. Come funziona una CTF?

Il funzionamento di una CTF dipende dalla piattaforma e dal tipo di competizione, ma generalmente il processo si articola in diverse fasi.

3.1 La presentazione della sfida

Ogni sfida viene accompagnata da una descrizione che spiega, direttamente o indirettamente, che cosa bisogna fare.

La descrizione può contenere informazioni sul problema, alcuni indizi e uno o più file da analizzare.

Per esempio, potrebbe essere fornito un programma che richiede una password, un'immagine che nasconde un messaggio oppure un'applicazione web da esaminare.

Non sempre la descrizione fornisce tutte le informazioni necessarie. Spesso una parte del lavoro consiste proprio nel capire quale sia il problema da risolvere.

3.2 L'analisi iniziale

Dopo aver letto la descrizione, bisogna analizzare il materiale disponibile.

Se si riceve un file, per esempio, è utile determinarne il formato, controllarne le dimensioni, cercare eventuali informazioni leggibili e verificare se contiene dati aggiuntivi.

Se si riceve un'applicazione web, invece, può essere necessario comprenderne le funzionalità, osservare le richieste HTTP e studiare il comportamento delle diverse pagine.

Questa fase è fondamentale perché permette di raccogliere informazioni prima di tentare una soluzione.

3.3 La formulazione di ipotesi

Una volta raccolti i primi dati, bisogna cercare di capire quale tecnica potrebbe essere utile.

Se una stringa contiene caratteri tipici della Base64, si può ipotizzare che si tratti di una codifica.

Se un programma si comporta in modo insolito quando riceve determinati input, si può cercare di comprendere quale parte della sua logica provochi quel comportamento.

Se un'immagine contiene informazioni apparentemente inutili, si può verificare se siano presenti metadati o dati nascosti.

L'obiettivo è formulare ipotesi ragionevoli e verificarle attraverso esperimenti controllati.

3.4 La risoluzione della sfida

A questo punto si utilizzano le tecniche e gli strumenti appropriati per raggiungere l'obiettivo.

Alcune sfide possono essere risolte con pochi comandi, mentre altre richiedono programmazione, analisi approfondita e numerosi tentativi.

È normale incontrare errori e dover modificare il proprio approccio. Il processo di risoluzione è spesso più importante della velocità con cui si arriva alla risposta.

3.5 L'invio della flag

Quando viene individuata la flag, questa viene inserita nella piattaforma della competizione.

Se la stringa è corretta, il sistema registra la soluzione e assegna gli eventuali punti previsti.

3.6 L'analisi della soluzione

Dopo aver completato una sfida, è utile rivedere tutti i passaggi eseguiti.

Molte piattaforme o comunità pubblicano i cosiddetti write-up, documenti che spiegano come una sfida sia stata risolta.

Studiare questi documenti permette di scoprire tecniche nuove, comprendere errori comuni e imparare approcci alternativi.

4. Le principali categorie delle CTF

Le CTF sono generalmente suddivise in categorie. Ogni categoria rappresenta un'area della sicurezza informatica e richiede conoscenze specifiche.

Le categorie possono variare da una competizione all'altra e non tutte le piattaforme utilizzano gli stessi nomi. Tuttavia, alcune sono particolarmente diffuse.

4.1 Web Exploitation

La categoria Web riguarda la sicurezza delle applicazioni web, come siti Internet, piattaforme online e API.

Le applicazioni web sono composte da diversi elementi: interfacce, server, database, sistemi di autenticazione e meccanismi che gestiscono le richieste degli utenti.

Una vulnerabilità può verificarsi quando uno di questi elementi viene progettato o implementato in modo scorretto.

Per esempio, un'applicazione potrebbe consentire a un utente di modificare un identificativo presente in una richiesta e visualizzare informazioni che dovrebbero essere accessibili soltanto a un altro utente. Questo comportamento potrebbe indicare un problema nei controlli di autorizzazione.

Le sfide Web possono richiedere di analizzare richieste HTTP, comprendere il funzionamento dei cookie, studiare il comportamento dei database o individuare errori nella gestione degli accessi.

Tra le vulnerabilità che si incontrano più frequentemente ci sono:

- SQL Injection, che riguarda l'inserimento non sicuro di dati nelle query SQL.
- Cross-Site Scripting (XSS), che può consentire l'esecuzione di codice JavaScript non previsto nel contesto di una pagina web.

- IDOR, una categoria di problemi in cui un'applicazione non verifica correttamente l'autorizzazione ad accedere a una risorsa.
- Errori di autenticazione e gestione delle sessioni.
- Errori di configurazione e controlli di accesso insufficienti.

Per affrontare questa categoria sono utili le conoscenze di HTML, JavaScript, HTTP, database e programmazione lato server.

Gli strumenti più utilizzati includono browser, strumenti per analizzare le richieste HTTP e proxy di test come Burp Suite e OWASP ZAP.

4.2 Cryptography

La crittografia studia i metodi utilizzati per proteggere le informazioni attraverso trasformazioni matematiche.

Nelle CTF, le sfide di crittografia possono richiedere di analizzare un messaggio cifrato, comprendere un algoritmo oppure individuare una debolezza nel modo in cui viene utilizzato.

Per esempio, una sfida potrebbe fornire un messaggio cifrato e alcuni parametri matematici, chiedendo di recuperare il testo originale.

Altre sfide sono più semplici e possono riguardare codifiche come Base64, cifrari classici oppure trasformazioni elementari delle lettere.

È fondamentale distinguere tre concetti.

La codifica trasforma i dati in una rappresentazione diversa. Base64, per esempio, permette di rappresentare dati binari attraverso caratteri testuali, ma non garantisce la riservatezza.

La cifratura trasforma i dati utilizzando un algoritmo e una chiave, con l'obiettivo di impedire a chi non possiede le informazioni necessarie di leggere il contenuto.

L'hashing applica una funzione che produce un valore derivato dai dati di ingresso. Gli hash crittografici sono progettati per determinate proprietà di sicurezza, ma non sono normalmente un sistema reversibile di cifratura.

Tra gli argomenti utili per questa categoria ci sono:

- Cifratura simmetrica e asimmetrica.
- RSA e AES.
- Funzioni hash.
- Chiavi crittografiche.
- Numeri primi e aritmetica modulare.
- Codifiche e cifrari classici.

La crittografia può richiedere conoscenze matematiche significative nelle sfide avanzate, ma esistono numerosi esercizi introduttivi adatti a chi inizia.

4.3 Reverse Engineering

Il Reverse Engineering, o ingegneria inversa, consiste nell'analizzare un programma per comprenderne il funzionamento interno.

Normalmente, uno sviluppatore scrive il codice sorgente di un programma, che può poi essere compilato in un eseguibile. In una sfida di reverse engineering, il partecipante può ricevere soltanto il programma compilato.

Deve quindi ricostruirne la logica osservando le istruzioni, le funzioni, le stringhe presenti e il comportamento durante l'esecuzione.

Per esempio, una challenge potrebbe fornire un eseguibile che richiede una password. Il compito consiste nel comprendere quali controlli vengono effettuati e individuare la condizione necessaria per ottenere la flag.

Le attività tipiche includono:

- Analizzare le stringhe contenute nel programma.
- Individuare le funzioni principali.
- Comprendere i confronti e le condizioni.
- Studiare le istruzioni in linguaggio assembly.
- Osservare il comportamento del programma durante l'esecuzione.
- Ricostruire algoritmi e controlli interni.

Gli strumenti comunemente utilizzati comprendono Ghidra, debugger e disassembler.

Per affrontare questa categoria sono utili conoscenze di programmazione, soprattutto in C, oltre a una comprensione di base della memoria, dei compilatori e dell'architettura dei calcolatori.

4.4 Pwn e Binary Exploitation

La categoria Pwn riguarda generalmente lo sfruttamento di vulnerabilità presenti nei programmi, spesso quelli compilati in linguaggi come C e C++.

A differenza del reverse engineering, che si concentra soprattutto sulla comprensione del funzionamento di un programma, il binary exploitation mira a comprendere come un errore possa essere utilizzato per alterarne il comportamento.

Una vulnerabilità classica è il buffer overflow.

Un buffer è una regione di memoria utilizzata per contenere dati. Se un programma gestisce male la quantità di dati ricevuti, può verificarsi una scrittura oltre i limiti previsti, con conseguenze potenzialmente pericolose.

Nelle CTF, questi problemi vengono studiati attraverso programmi appositamente predisposti per l'esercizio.

Gli argomenti più importanti includono:

- Gestione della memoria.
- Stack e heap.
- Puntatori.

- Linguaggio C.
- Assembly.
- Registri del processore.
- Debugging.
- Mitigazioni come ASLR e stack canary.

Gli strumenti tipici comprendono GDB, pwndbg e pwntools.

Questa categoria è spesso impegnativa per i principianti perché richiede di comprendere in modo preciso come vengono eseguite le istruzioni e come vengono organizzati i dati in memoria.

4.5 Digital Forensics

La Digital Forensics, o informatica forense, consiste nell'analizzare dati digitali per ricostruire eventi, individuare informazioni rilevanti e comprendere ciò che è accaduto all'interno di un sistema.

Nelle CTF, i materiali forniti possono includere immagini disco, file di log, catture di memoria, archivi e documenti.

Per esempio, una sfida potrebbe fornire una serie di registri di sistema e chiedere di identificare un'attività specifica o ricostruire la sequenza di determinati eventi.

Il partecipante deve cercare informazioni utili e collegare gli indizi disponibili.

Tra gli elementi che possono essere analizzati troviamo:

- Metadati dei file.
- Timestamp.
- Log di sistema.
- File cancellati o residui.
- Immagini disco.
- Dati presenti nella memoria.
- Cronologia delle attività.

Gli strumenti utilizzati possono includere Autopsy, Volatility, ExifTool e strumenti per l'analisi dei file.

La digital forensics richiede precisione, capacità di osservazione e attenzione alla provenienza delle informazioni. Nella pratica professionale, la conservazione dell'integrità delle prove e la documentazione delle operazioni sono aspetti essenziali.

4.6 Network

La categoria Network riguarda le reti informatiche e i protocolli utilizzati dai dispositivi per comunicare.

Quando due computer comunicano, scambiano dati attraverso protocolli che definiscono come le informazioni vengono organizzate e trasmesse.

Una sfida di rete può fornire un file PCAP, cioè una cattura di pacchetti, chiedendo di individuare una comunicazione interessante o recuperare informazioni presenti nel traffico.

Per risolvere questo tipo di problema bisogna comprendere almeno in parte come funzionano i protocolli di rete.

Gli argomenti principali sono:

- Indirizzi IP.
- Porte di comunicazione.
- TCP e UDP.
- DNS.
- HTTP e HTTPS.
- Pacchetti di rete.
- Protocolli applicativi.

Lo strumento più conosciuto per analizzare il traffico è Wireshark, che permette di osservare i pacchetti, applicare filtri e ricostruire alcune comunicazioni.

Questa categoria è particolarmente utile per chi desidera approfondire il funzionamento delle reti e delle infrastrutture informatiche.

4.7 Steganography

La steganografia consiste nel nascondere informazioni all'interno di altri contenuti, cercando di rendere poco evidente la presenza del messaggio.

Per esempio, un'immagine potrebbe contenere dati nascosti nei pixel, nei metadati o in informazioni aggiuntive incorporate nel file.

In una CTF, potrebbe essere fornita un'immagine apparentemente normale e richiesto di individuare il contenuto nascosto.

Le tecniche di analisi possono comprendere:

- Controllo dei metadati.
- Analisi della struttura del file.
- Ricerca di dati aggiuntivi.
- Analisi dei bit dei pixel.
- Estrazione di informazioni incorporate.

Tra gli strumenti utili ci sono ExifTool e binwalk, oltre a programmi specifici per l'analisi di immagini e file multimediali.

È importante distinguere la steganografia dalla crittografia: la prima cerca di nascondere l'esistenza di un messaggio, mentre la seconda mira a proteggerne il contenuto.

Le due tecniche possono comunque essere utilizzate insieme.

4.8 OSINT

OSINT significa Open Source Intelligence e indica la raccolta e l'analisi di informazioni provenienti da fonti pubblicamente accessibili.

Nelle CTF, una sfida OSINT può richiedere di identificare un luogo a partire da un'immagine, trovare una data attraverso informazioni pubbliche oppure collegare diversi indizi per ottenere una risposta.

Le attività possono includere:

- Ricerca avanzata sul web.
- Analisi di immagini.
- Esame dei metadati.
- Geolocalizzazione.
- Verifica delle fonti.
- Correlazione delle informazioni.

A differenza di molte altre categorie, l'OSINT non richiede necessariamente la scrittura di codice o l'analisi di vulnerabilità.

5. Il metodo corretto per risolvere una sfida

Un metodo organizzato aiuta a evitare tentativi casuali e permette di comprendere meglio il problema.

Il primo passo consiste nel leggere attentamente la descrizione. Bisogna capire quale risultato viene richiesto e quali informazioni sono già disponibili.

Successivamente si analizza il materiale fornito. Se si tratta di un file, è utile identificarne il formato e cercare informazioni iniziali. Se si tratta di un'applicazione, bisogna osservarne il comportamento.

Il passaggio successivo consiste nel formulare un'ipotesi. Per esempio, si può sospettare che una stringa sia codificata in Base64 oppure che un programma contenga un controllo particolare.

A questo punto si sceglie uno strumento adatto e si verifica l'ipotesi.

È importante procedere un passo alla volta, osservando i risultati. Se l'ipotesi non viene confermata, bisogna considerare altre possibilità.

Durante il processo è utile annotare i comandi eseguiti, le informazioni raccolte e gli errori incontrati in un write-up che è un documento che descrive come è stata risolta una sfida CTF. Generalmente contiene la descrizione del problema, l'analisi iniziale, gli strumenti utilizzati, i passaggi eseguiti e la spiegazione della soluzione.

Un buon write-up non si limita a elencare i comandi utilizzati. Spiega perché quei comandi sono stati scelti, quali informazioni hanno fornito e come hanno permesso di arrivare al risultato.

Un buon write-up può avere questa struttura:

1. Titolo e categoria: nome della sfida e tipo di problema.
2. Descrizione: che cosa veniva richiesto e quali materiali erano disponibili.
3. Analisi iniziale: quali controlli hai eseguito e quali informazioni hai raccolto.
4. Ipotesi: quali possibili spiegazioni hai considerato.

5. Procedimento: i passaggi utilizzati per risolvere il problema, con spiegazione dei comandi rilevanti.
6. Risultato: come hai verificato la soluzione e ottenuto la flag.
7. Lezioni apprese: quale concetto hai imparato e che cosa faresti diversamente la prossima volta.

Infine, dopo aver trovato la flag, è consigliabile rivedere il procedimento e cercare di capire perché ha funzionato.